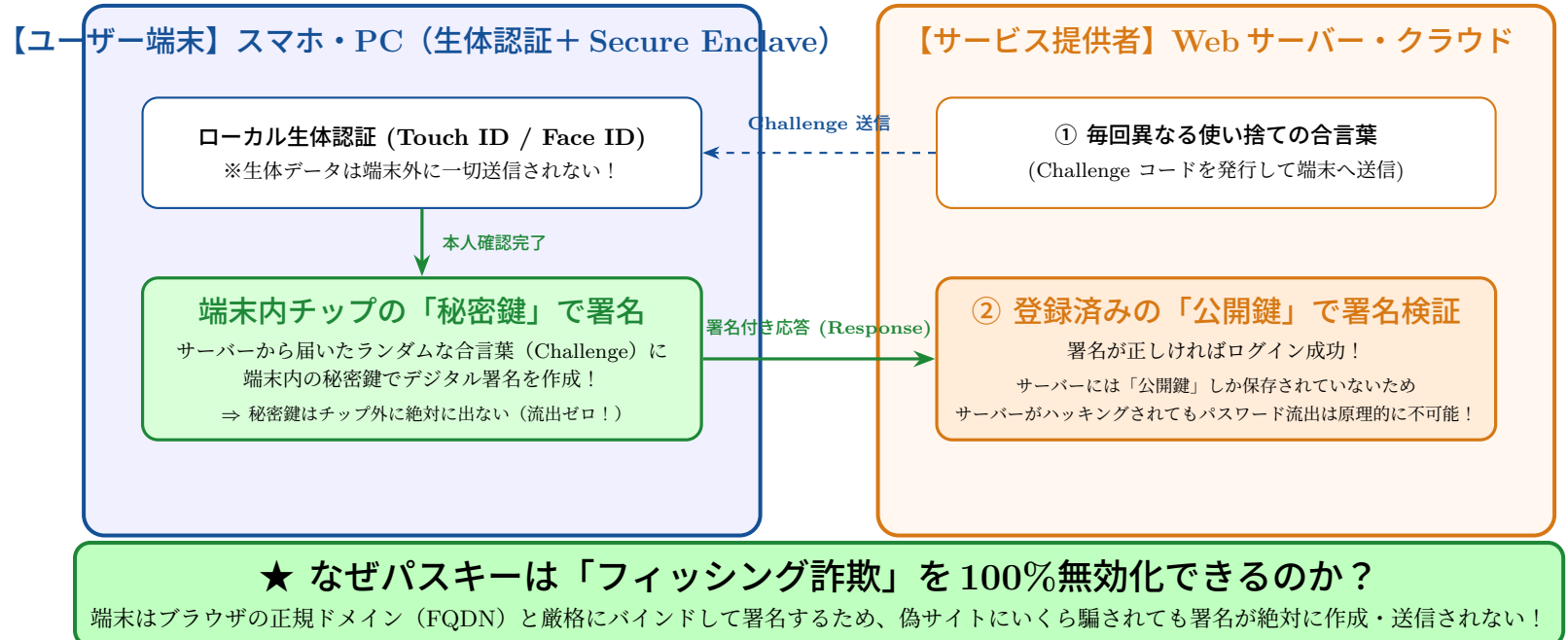

【ユーザー端末】スマホ・PC（生体認証＋ Secure Enclave）
【サービス提供者】Web サーバー・クラウド
ローカル生体認証 (Touch ID / Face ID)
※生体データは端末外に一切送信されない！
Challenge 送信
① 毎回異なる使い捨ての合言葉
(Challenge コードを発行して端末へ送信)
本人確認完了
端末内チップの「秘密鍵」で署名
サーバーから届いたランダムな合言葉（Challenge）に
端末内の秘密鍵でデジタル署名を作成！
⇒ 秘密鍵はチップ外に絶対に出ない（流出ゼロ！）
署名付き応答（Response）
② 登録済みの「公開鍵」で署名検証
署名が正しければログイン成功！
サーバーには「公開鍵」しか保存されていないため
サーバーがハッキングされてもパスワード流出は原理的に不可能！
★ なぜパスキーは「フィッシング詐欺」を 100％無効化できるのか？
端末はブラウザの正規ドメイン（FQDN）と厳格にバインドして署名するため、偽サイトにいくら騙されても署名が絶対に作成・送信されない！